

SMB Security Posture Checklist

Aligned to NIST Cybersecurity Framework (CSF) 2.0 — 42 Controls

Organization Assessed: _____

Date of Assessment: _____

Assessed By: _____

Automated Scan Reference / Report ID: _____

This checklist is used to manually verify that the automated agent pipeline correctly evaluated each control below, and to record findings for controls that require human judgment. The **Type** column indicates whether a control is checked automatically by the scanning agents, is planned for future automation, or inherently requires manual review.

GOVERN (GV)

ID	Category	Description	Type	Verified
GV-01	Organizational Context	Business objectives and stakeholders are identified and documented	Manual	■
GV-02	Risk Management Strategy	Risk tolerance and appetite are defined	Manual	■
GV-03	Roles & Responsibilities	Cybersecurity roles and responsibilities are assigned	Manual	■
GV-04	Policy	An information security policy exists and is communicated	Manual	■
GV-05	Oversight	Cybersecurity risk is reviewed by leadership on a regular basis	Manual	■
GV-06	Supply Chain	Third-party vendors and software supply chain risks are assessed	Manual	■
GV-07	Compliance	Legal and regulatory requirements are identified and tracked	Manual	■

IDENTIFY (ID)

ID	Category	Description	Type	Verified
ID-01	Asset Management	Physical devices and systems on the network are inventoried	Automated	■
ID-02	Asset Management	Software and applications installed are inventoried	Planned	■
ID-03	Asset Management	Operating system versions and build numbers are identified	Automated	■
ID-04	Risk Assessment	Known vulnerabilities on identified assets are cataloged	Planned	■
ID-05	Risk Assessment	Patch/update status is assessed against vendor release cadence	Automated	■
ID-06	Business Environment	Critical business functions dependent on IT systems are documented	Manual	■
ID-07	Governance	Data classification (what's sensitive vs not) is defined	Manual	■

PROTECT (PR)

ID	Category	Description	Type	Verified
PR-01	Access Control	User accounts follow least-privilege principles	Planned	■
PR-02	Access Control	Multi-factor authentication is enabled on admin/critical accounts	Planned	■
PR-03	Data Security	Sensitive data at rest is encrypted	Planned	■
PR-04	Data Security	Data in transit is encrypted (HTTPS/TLS enforced)	Planned	■
PR-05	Platform Security	Host-based firewall is enabled on all endpoints	Automated	■
PR-06	Platform Security	Operating systems are patched within a defined SLA (e.g. 30 days)	Automated	■
PR-07	Platform Security	Antivirus/endpoint protection is installed and active	Planned	■
PR-08	Maintenance	Remote maintenance access is logged and controlled	Manual	■
PR-09	Awareness & Training	Staff receive periodic security awareness training	Manual	■
PR-10	Network Security	Network segmentation separates critical systems from general traffic	Manual	■
PR-11	Backup	Regular backups are performed and tested for restoration	Manual	■
PR-12	Physical Security	Physical access to servers/network equipment is restricted	Manual	■

DETECT (DE)

ID	Category	Description	Type	Verified
DE-01	Anomaly Detection	Unusual login attempts or access patterns are monitored	Planned	■
DE-02	Continuous Monitoring	Network traffic is monitored for known malicious indicators	Planned	■
DE-03	Continuous Monitoring	New/unauthorized devices joining the network are flagged	Automated	■
DE-04	Logging	Security-relevant events are logged centrally	Planned	■
DE-05	Vulnerability Scanning	Systems are periodically scanned for missing patches	Automated	■
DE-06	Detection Processes	Detection processes are tested periodically	Manual	■
DE-07	Firewall Rule Review	Firewall rules are reviewed for overly permissive configurations	Planned	■

RESPOND (RS)

ID	Category	Description	Type	Verified
RS-01	Response Planning	An incident response plan exists	Manual	■
RS-02	Communications	Roles for internal/external incident communication are defined	Manual	■
RS-03	Analysis	Incidents are investigated and root cause is documented	Manual	■
RS-04	Mitigation	Compromised systems can be isolated quickly	Manual	■
RS-05	Improvements	Lessons learned from incidents update future response plans	Manual	■
RS-06	Reporting	Regulatory breach notification requirements are known and actionable	Manual	■

RECOVER (RC)

ID	Category	Description	Type	Verified
RC-01	Recovery Planning	A disaster recovery plan exists and is documented	Manual	☐
RC-02	Improvements	Recovery plans are updated based on lessons learned	Manual	☐
RC-03	Communications	Recovery activities are communicated to stakeholders	Manual	☐

Verified complete and accurate by: _____ Signature: _____ Date: _____

Generated as part of the Agentic SMB Security Posture project. Control set adapted from NIST Cybersecurity Framework (CSF) 2.0. This checklist is provided for internal review and demonstration purposes and does not constitute a certified compliance audit.